Julianna Russo, Gianna Julio, Daisy Kopycienski CMPT417 - Hacking and Pen Testing
4/5/2024 Altoro Lab 6

This assignment locates a hidden CGI executable file within a misconfigured page on the Altoro Mutual website. From this executable, we can find other hidden configuration files and links used within the Altoro Mutual website.

Assignment 6: Finding hidden files
Difficulty Level: Black Hat Rock Star

Perhaps there's another misconfiguration error on this website, which would allow us to locate hidden files or directory structures. Before you place your trust in a development platform, you should understand its vulnerabilities. If we can get access to different types of files, we could look up known vulnerabilities against these files and try to run exploits on this site.

1. From the Altoro Mutual homepage, try exploring all the links under "Inside Altoro Mutual". One of them is misconfigured and will generate an error message, but look at the URL window… there's a file that could be downloaded to your computer with the right tools. To keep things simple, I've put a version of this file in iLearn for you. Based on the file name (which is an acronym) what is this file supposed to do?

   "Locations" link generates an error message: **An Error Has Occurred**

   Page could not be found.

   A CGI (Common Gateway Interface) file is a standard way to run programs from a web server. CGI files contain programs that process HTTP/S user requests.

2. Normally you would investigate unknown executable files on a separate pen testing computer, not the one you use for daily work, and there are special tools you can use to "sandbox" the program in case it's malicious. You should never run an unknown executable file on your computer. For this example, let's open a command line window, go to the downloads directory, and try to see what the file does by typing its name at the command prompt. What do you think this file is supposed to do?

This file contains the HTML code that is supposed to represent the “Locations” webpage for Altoro Mutual.


```
Content-type: text/html

<html><head><title>Altoro Mutual: Locations</title><meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1"><link href="style.css" rel="styles
heet" type="text/css" /></head><body><div id="header" style="width: 99%;"><form id="frmSearch" method="get" action="search.aspx"><table width="100%" border="
0" cellpadding="0" cellspacing="0"><tr><td rowspan="3"><a href="default.aspx" style="height:98px;width:183px;"><img src="images/logo.gif" border="0" /></a></
td><td align="right" valign="top"><a href="bank/login.aspx" style="color:Red;font-weight:bold;">Sign In</a> | <a href="default.aspx?content=inside_contact.ht
m">Contact Us</a> | <a href="feedback.aspx">Feedback</a> | <label for="txtSearch">Search</label> <input type="text" name="txtSearch" id="txtSearch" accesskey
="S" /><input type="submit" name="btnSubmit" id="btnSubmit" value="Go" /></td></tr><tr><td align="right"><img src="images/header_pic.jpg" border="0" style="h
eight:60px;width:468px;" /></td></tr></table></form></div><div id="wrapper" style="width: 99%;"><table cellspacing="0" width="100%"><tr><td width="25%" class
="bt br bb"><div ><img src="images/pf_lock.gif" alt="Secure Login" align="absbottom" border="0" style="height:14px;width:12px;" />   <a class="focus" hr
ef="bank/login.aspx">ONLINE BANKING LOGIN</a></div></td><td width="25%" class="cc bt br bb"><div ><a class="focus" href="default.aspx?content=personal.htm">P
ERSONAL</a></div></td><td width="25%" class="cc bt br bb"><div ><a class="focus" href="default.aspx?content=business.htm">SMALL BUSINESS</a></div></td><td wi
dth="25%" class="cc bt bb"><div ><a class="focus" href="default.aspx?content=inside.htm">INSIDE ALTORO MUTUAL</a></div></td></tr><tr><td valign="top" class="
cc br bb"><br /><a class="subheader" href="default.aspx?content=personal.htm">PERSONAL</a><ul class="sidebar"><li><a href="default.aspx?content=personal_depo
sit.htm">Deposit Product</a></li><li><a href="default.aspx?content=personal_checking.htm">Checking</a></li><li><a href="default.aspx?content=personal_loans.h
tm">Loan Products</a></li><li><a href="default.aspx?content=personal_cards.htm">Cards</a></li><li><a href="default.aspx?content=personal_investments.htm">Inv
estments &amp; Insurance</a></li><li><a href="default.aspx?content=personal_other.htm">Other Services</a></li></ul><a class="subheader" href="default.aspx?co
ntent=business.htm">SMALL BUSINESS</a><ul class="sidebar"><li><a href="default.aspx?content=business_deposit.htm">Deposit Products</a></li><li><a href="defau
lt.aspx?content=business_lending.htm">Lending Services</a></li><li><a href="default.aspx?content=business_cards.htm">Cards</a></li><li><a href="default.aspx?
content=business_insurance.htm">Insurance</a></li><li><a href="default.aspx?content=business_retirement.htm">Retirement</a></li><li><a href="default.aspx?con
tent=business_other.htm">Other Services</a></li></ul><a class="focus" href="default.aspx?content=inside.htm">INSIDE ALTORO MUTUAL</a><ul class="sidebar"><li>
<a href="default.aspx?content=inside_about.htm">About Us</a></li><li><a href="default.aspx?content=inside_contact.htm">Contact Us</a></li><li><a href="cgi.ex
e">Locations</a></li><li><a href="default.aspx?content=inside_investor.htm">Investor Relations</a></li><li><a href="default.aspx?content=inside_press.htm">Pr
ess Room</a></li><li><a href="default.aspx?content=inside_careers.htm">Careers</a></li></ul></td><td valign="top" colspan="3" class="bb"><div class="fl" styl
e="width: 99%;"><h1>Locations</h1><p>Please choose your geographic location:<ul><li><a href="cgi.exe?m=NorthAmerica">North America</a></li><li><a href="cgi.e
xe?m=Europe">Europe</a></li><li><a href="cgi.exe?m=AsiaPacific">Asia-Pacific</a></li></ul></p></div></td></tr></table></div><div id="footer" style="width: 99
%;"><a href="default.aspx?content=privacy.htm">Privacy Policy</a>  |  <a href="default.aspx?content=security.htm">Security Statement</a>&
nbsp; |  &copy; 2006 Altoro Mutual, Inc.<div class="disclaimer">The Altoro Mutual website is published by Watchfire, Inc. for the sole purpose
 of demonstrating the effectiveness of Watchfire products in detecting web application vulnerabilities and website defects. This site is not a real banking s
ite. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, eithe
r express or implied. Watchfire does not assume any risk in relation to your use of this website. For additional Terms of Use, please go to <a href="http://w
ww.watchfire.com/statements/terms.aspx">http://www.watchfire.com/statements/terms.aspx</a>.<br /><br />Copyright &copy; 2006, Watchfire Corporation, All righ
ts reserved.</div></div></body></html>
```


3. Search for href tags in the file to see if we can extract any directory listings (you might find it easier to copy/paste the file contents into a searchable text editor rather than searching manually). Note there is an href anchor tag for a directory called /bank/login.aspx; what’s an aspx filetype and what is it used for?

   A file with a .aspx extension is a webpage generated using Microsoft ASP.NET framework running on web servers. ASPX stands for Active Server Pages Extended and these pages are displayed in web browser at user end when the URL is accessed.

4. If we try accessing this page by visiting http://demo.testfire.net/bank/login.aspx.cs you’ll find that it redirects to http://demo.testfire.net/login.jsp. What is a .jsp filetype and what is it used for?

   A JSP file with a .jsp extension is a JavaServer Page, an extensible Web technology that uses template data, custom elements, scripting languages, and server-side Java objects to return dynamic content to a client.